

REPORTE EJECUTIVO DE GESTIÓN DE RIESGOS

Clínica Privada — Registro Inicial de Riesgos

Fecha: 9 de septiembre de 2026

Destinatario: Directorio de la Clínica

1. Resumen ejecutivo

Como resultado de la evaluación inicial de riesgos de seguridad de la información, se identificaron **7 riesgos relevantes** que afectan principalmente la confidencialidad, integridad y disponibilidad de los sistemas y de la información de la clínica.

La organización cuenta con aproximadamente **120 empleados y atiende a unos 800 pacientes por día**, utilizando sistemas digitales para gestionar historias clínicas, información de obras sociales y procesos de facturación. Esta elevada dependencia de la tecnología hace que la disponibilidad y protección de la información sean aspectos críticos para la continuidad de las operaciones y la atención de los pacientes.

Los riesgos de mayor prioridad corresponden al **ransomware sobre los sistemas de historias clínicas** y al **acceso no autorizado a información clínica**, ambos con una valoración de **20/25 (4 × 5)**. También se identificaron riesgos altos asociados al phishing, la indisponibilidad de los sistemas, la fuga de información y la alteración no autorizada de información clínica.

Como respuesta inicial se definieron **3 planes de acción prioritarios**, orientados a fortalecer las copias de seguridad, implementar autenticación multifactor y reducir la exposición al phishing. El presupuesto total estimado para estas acciones es de **USD 14.000**.

La principal recomendación al Directorio es priorizar las medidas que reduzcan simultáneamente el riesgo de interrupción de los servicios clínicos y la exposición de información sensible.

2. Top 5 de riesgos

Prioridad	Riesgo	Prob.	Impacto	Nivel	Tratamiento
1	Ransomware sobre sistemas de historias clínicas	4	5	20 — Muy alto	Mitigar
2	Acceso no autorizado a historias clínicas	4	5	20 — Muy alto	Mitigar
3	Phishing y robo de credenciales	4	4	16 — Alto	Mitigar
4	Indisponibilidad del sistema de historias clínicas	3	5	15 — Alto	Mitigar
5	Fuga de información de pacientes y obras sociales	3	5	15 — Alto	Mitigar

Principales observaciones

Ransomware — 20/25.

Una infección de ransomware podría impedir el acceso a las historias clínicas digitales y afectar directamente la atención de aproximadamente 800 pacientes diarios. Se recomienda priorizar backups offline o inmutables, MFA, actualización de sistemas, segmentación de red y pruebas periódicas de recuperación.

Acceso no autorizado — 20/25.

Las historias clínicas contienen información médica y personal altamente sensible. Un acceso indebido podría generar consecuencias legales, económicas y reputacionales. Se recomienda reforzar el mínimo privilegio, MFA, revisión periódica de permisos y monitoreo de accesos.

Phishing — 16/25.

El compromiso de una cuenta puede convertirse en una puerta de entrada a los sistemas clínicos y administrativos. La capacitación periódica, las simulaciones de phishing y los mecanismos de reporte deben constituir una medida preventiva permanente.

Indisponibilidad — 15/25.

Las fallas de infraestructura, almacenamiento o software pueden interrumpir los servicios clínicos. Se recomienda incorporar redundancia, monitoreo, procedimientos formales de contingencia y objetivos RTO/RPO.

Fuga de información — 15/25.

La exposición accidental o intencional de información médica, personal, de obras sociales o de facturación representa un impacto elevado para la organización. Se recomienda fortalecer la clasificación de información, el cifrado, el control de accesos y el monitoreo de transferencias.

3. Estado de los planes de acción

Se definieron 3 **planes de acción prioritarios**, todos actualmente en estado **Not Started**.

Plan	Acción	Vencimiento	Responsable	Presupuesto	Estado
PA-01	Backups resilientes contra ransomware	30/11/2026	Director de Sistemas / Infraestructura	USD 8.000	Not Started
PA-02	Implementación de MFA para sistemas críticos	31/10/2026	Seguridad de la Información	USD 4.000	Not Started
PA-03	Capacitación y simulación de phishing	15/10/2026	Seguridad de la Información / RR.HH.	USD 2.000	Not Started

Presupuesto total estimado: USD 14.000.

La prioridad temporal sugerida es comenzar por **PA-03**, debido a su fecha de vencimiento más cercana y a que permite reducir rápidamente la exposición asociada al phishing. En paralelo, debe iniciarse **PA-02**, mientras que **PA-01** requiere una planificación técnica y pruebas de recuperación antes de su puesta en producción.

4. Recomendaciones prioritarias al Directorio

1. Priorizar la protección de las historias clínicas

La disponibilidad e integridad de la información clínica deben considerarse activos críticos. Se recomienda establecer como prioridad institucional la protección del sistema de historias clínicas y su capacidad de recuperación ante incidentes.

2. Aprobar los tres planes de acción iniciales

Se recomienda aprobar el presupuesto estimado de **USD 14.000** para implementar las medidas de backups resilientes, MFA y concientización contra phishing.

3. Garantizar capacidad de recuperación ante ransomware

Las copias de seguridad deben mantenerse separadas de la infraestructura productiva y contar, como mínimo, con una copia offline o inmutable. Además, las restauraciones deben probarse periódicamente.

4. Fortalecer el control de acceso

Se recomienda implementar MFA en los sistemas críticos, aplicar el principio de mínimo privilegio, revisar periódicamente los permisos y eliminar inmediatamente las cuentas de usuarios desvinculados.

5. Establecer un programa permanente de seguridad

La gestión de riesgos no debería limitarse a esta evaluación inicial. Se recomienda realizar revisiones periódicas de riesgos, controles, permisos, vulnerabilidades y planes de tratamiento, informando al Directorio sobre su evolución.